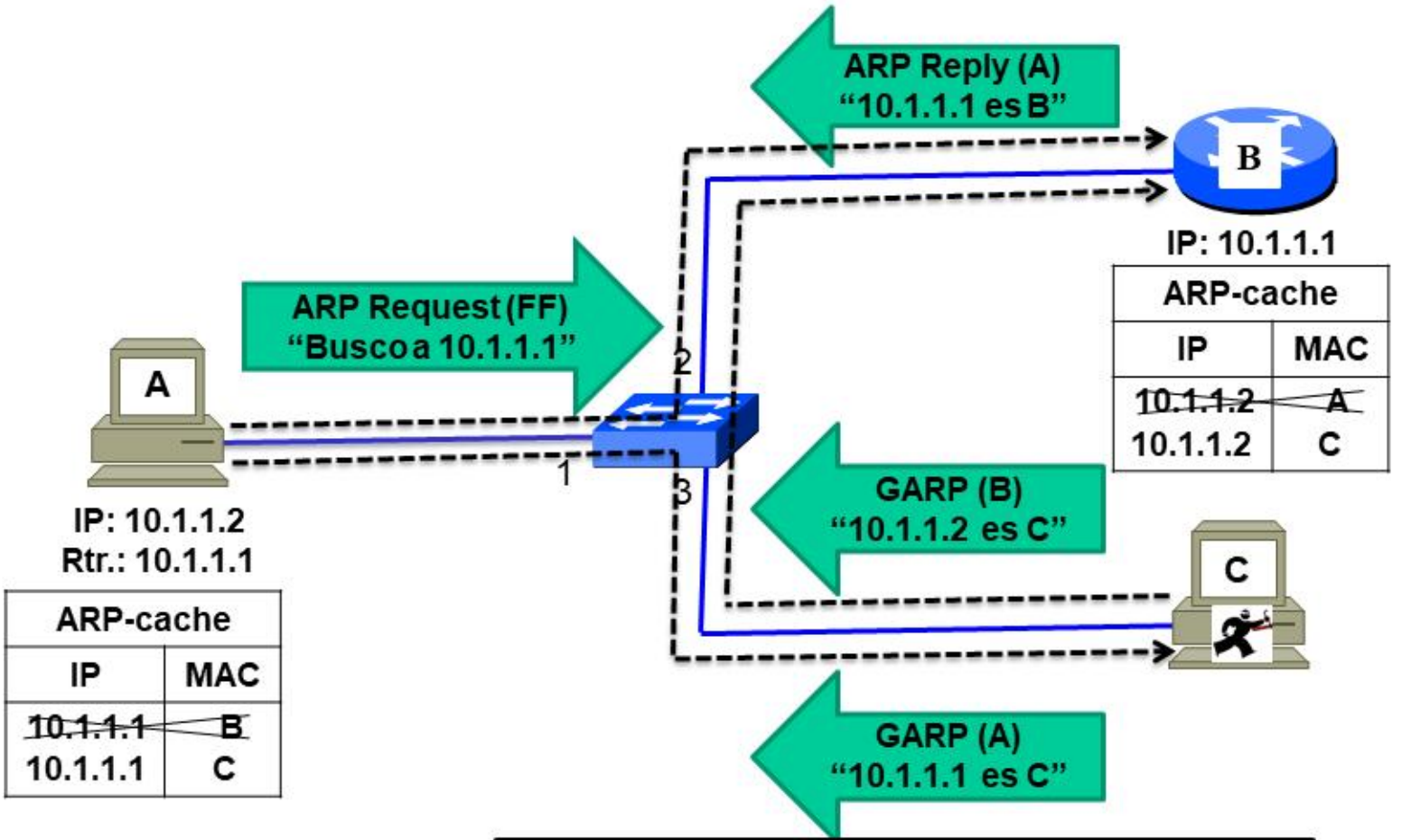
Ataques de 'spoofing' (suplantación de identidad)

- Consisten en utilizar una dirección falsa para obtener un acceso no autorizado. Se puede hacer de diferentes maneras:
  - ARP spoofing: se falsea la información de la ARP-cache mediante el envío de mensajes ARP falsos
  - IP spoofing: un equipo utiliza la dirección IP de otro
  - MAC spoofing: un equipo utiliza la dirección MAC de otro
  - Diversas combinaciones de los tres anteriores
- OJO: no confundir 'spoofing' con 'snooping'

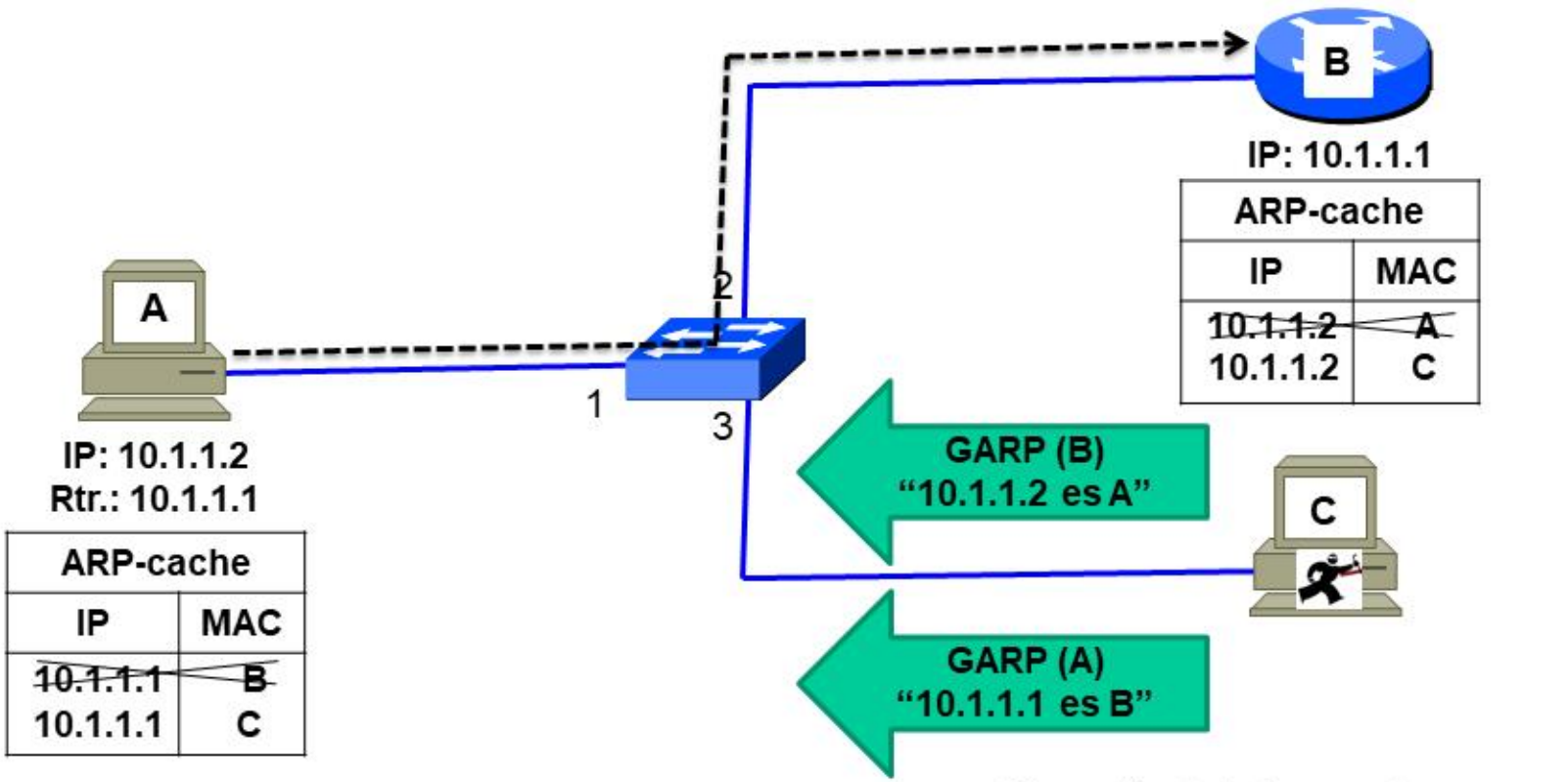
ARP spoofing, o envenenamiento de ARP

- Para averiguar una IP los hosts envían ARP Request (broadcast)
- Todos los Hosts en la LAN procesan el ARP Request; el dueño de la IP buscada responde con un ARP Reply
- Pero ARP no es seguro, cualquier host puede decir que posee una IP, sea o no cierto.
- Enviando ARP gratuitos un host puede desplazar a otro de las ARP-cache de sus interlocutores, y hacer un ataque de hombre en medio.
- En el funcionamiento normal los hosts no pueden comprobar la veracidad de la información

ARP spoofing, ataque



ARP spoofing, limpieza



Después del ataque el agresor limpia todos los rastros

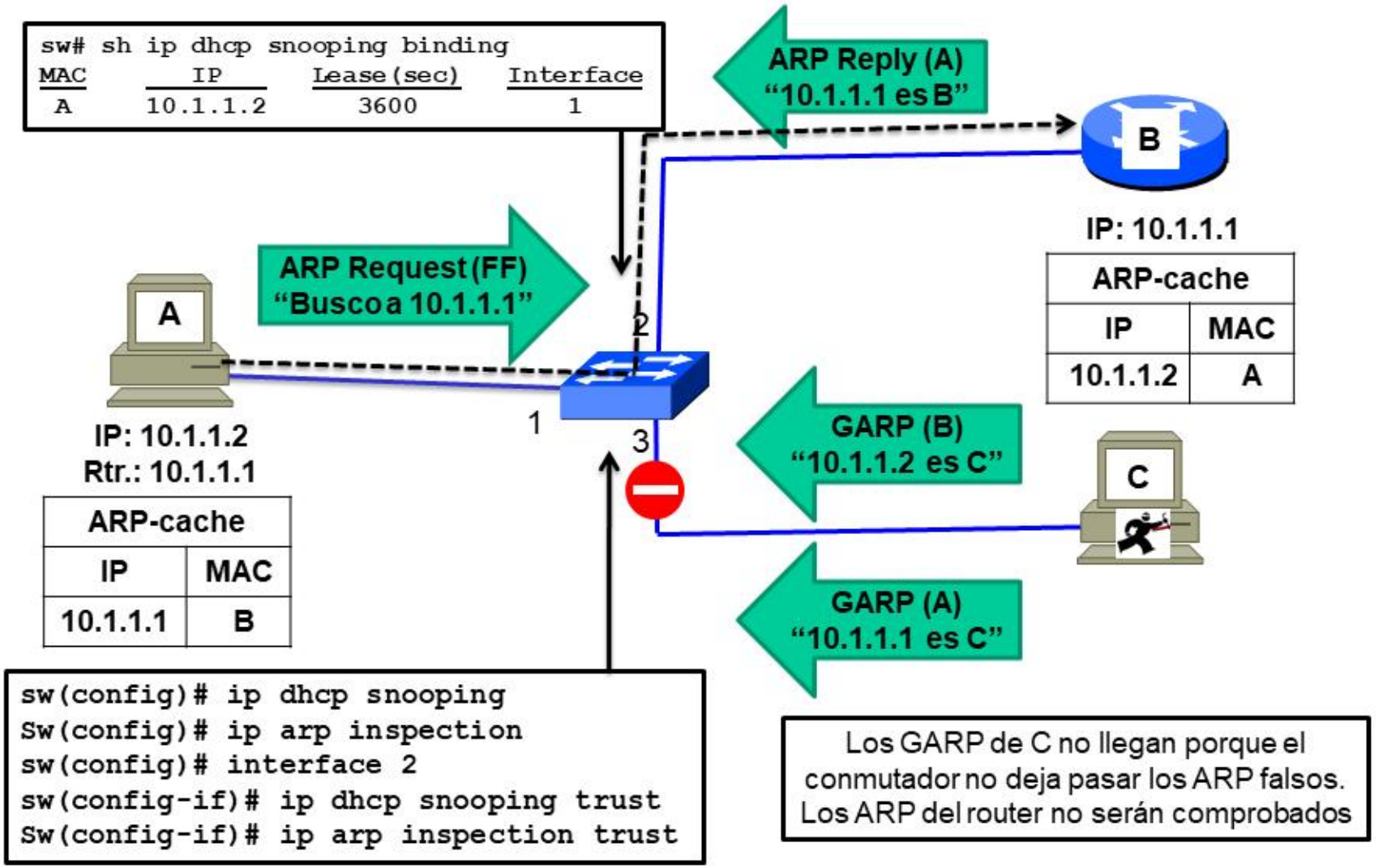
Solución al ARP spoofing (I)

- Para detectar este ataque hay que saber cuando un host miente en los ARP que envía
- Para ello los conmutadores comparan la información de los mensajes ARP con la de la 'DHCP binding table' que ellos se contruyen con los mensajes DHCP Reply y el DHCP snooping
- La acción de husmear los paquetes ARP no se llama ARP snooping sino '**ARP Inspection**' o '**ARP Security**'.

Solución al ARP spoofing (II)

- Cuando un ARP pasa por el conmutador éste comprueba que la MAC e IP indicados correspondan con lo que dice la binding table; si hay discrepancia el mensaje se descarta (y el puerto puede desactivarse).
- El ARP Inspection se puede deshabilitar en algunos puertos que se consideran de confianza (puertos 'turst'). Por defecto los puertos son 'no trust'. El modo trust es necesario:
  - Para los host (o routers) que no se configuran por DHCP
  - Para los que hacen Proxy ARP
- Otra forma de evitar el ataque ARP sería llenar a mano la ARP cache de los hosts con entradas estáticas. Pero esto requiere mucha labor administrativa por lo que no suele hacerse.

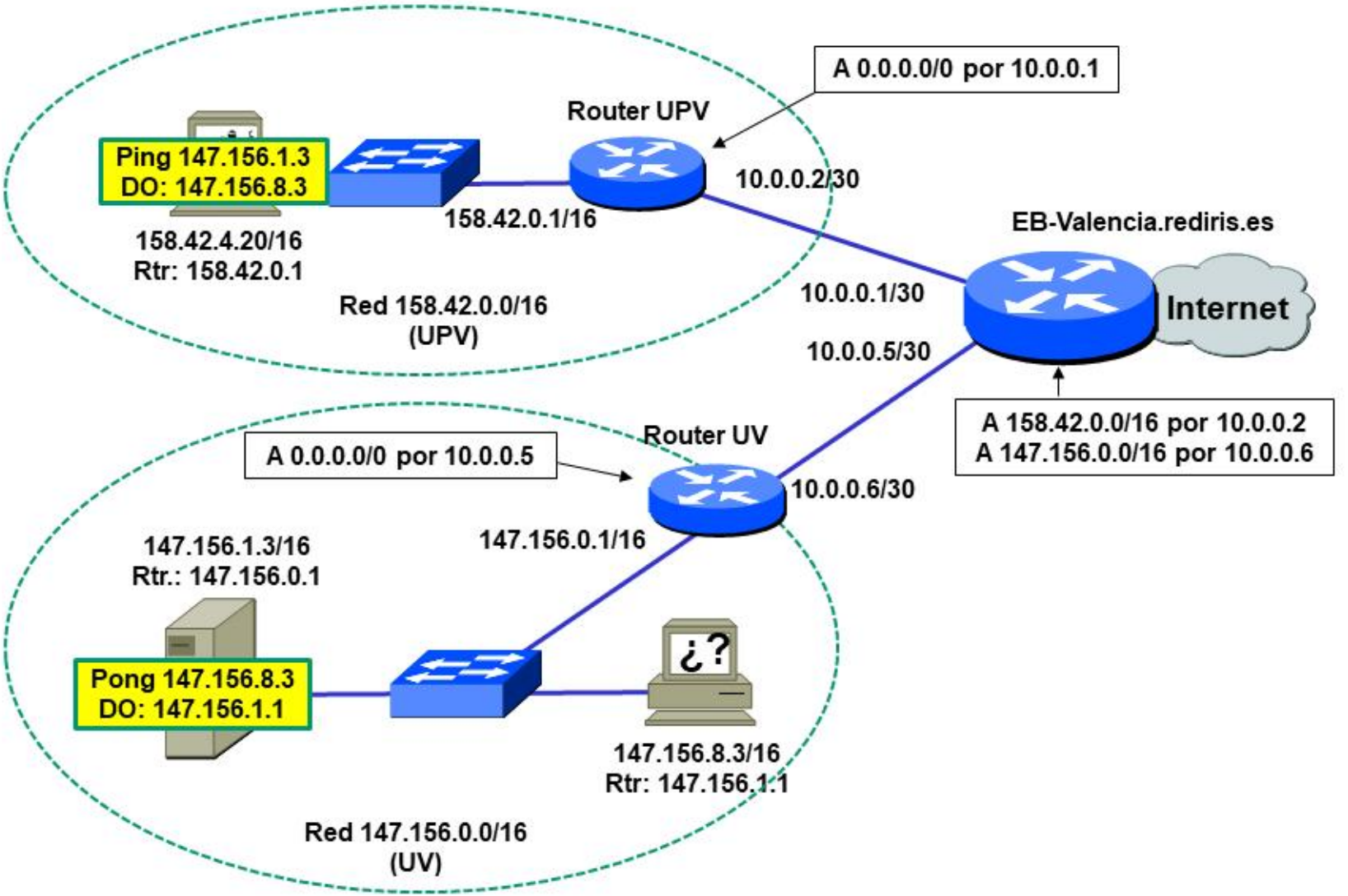
ARP spoofing, configuración protegida



IP spoofing

- Generalmente el IP spoofing lo usan los atacantes para evitar ser pillados. La víctima puede ser la IP de destino, o la de origen.
- Muchos ataques de denegación de servicio se basan en desbordar recursos de un servidor enviando muchas peticiones con diferentes IPs de origen, todas falsas, desde un mismo host.
- Cuando las peticiones se envían a muchos hosts poniendo en todas la misma IP de origen el atacado será esa IP (la de origen) cuando reciba todas las respuestas.
- Generalmente en estos casos el atacante no llega a ver las respuestas. Pero esto no es un problema en los ataques de denegación de servicio.

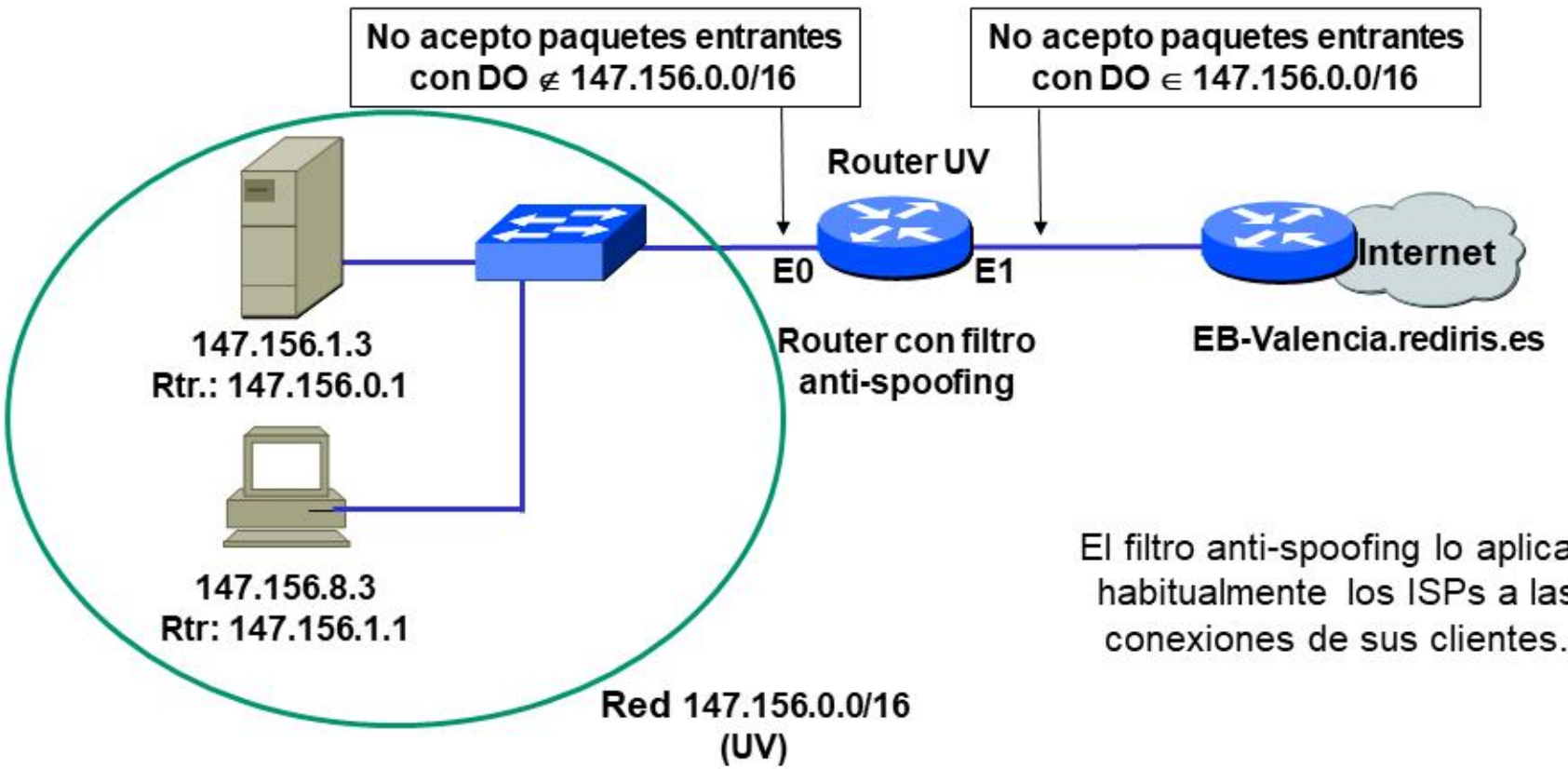
Ejemplo de IP spoofing



Solución al IP spoofing

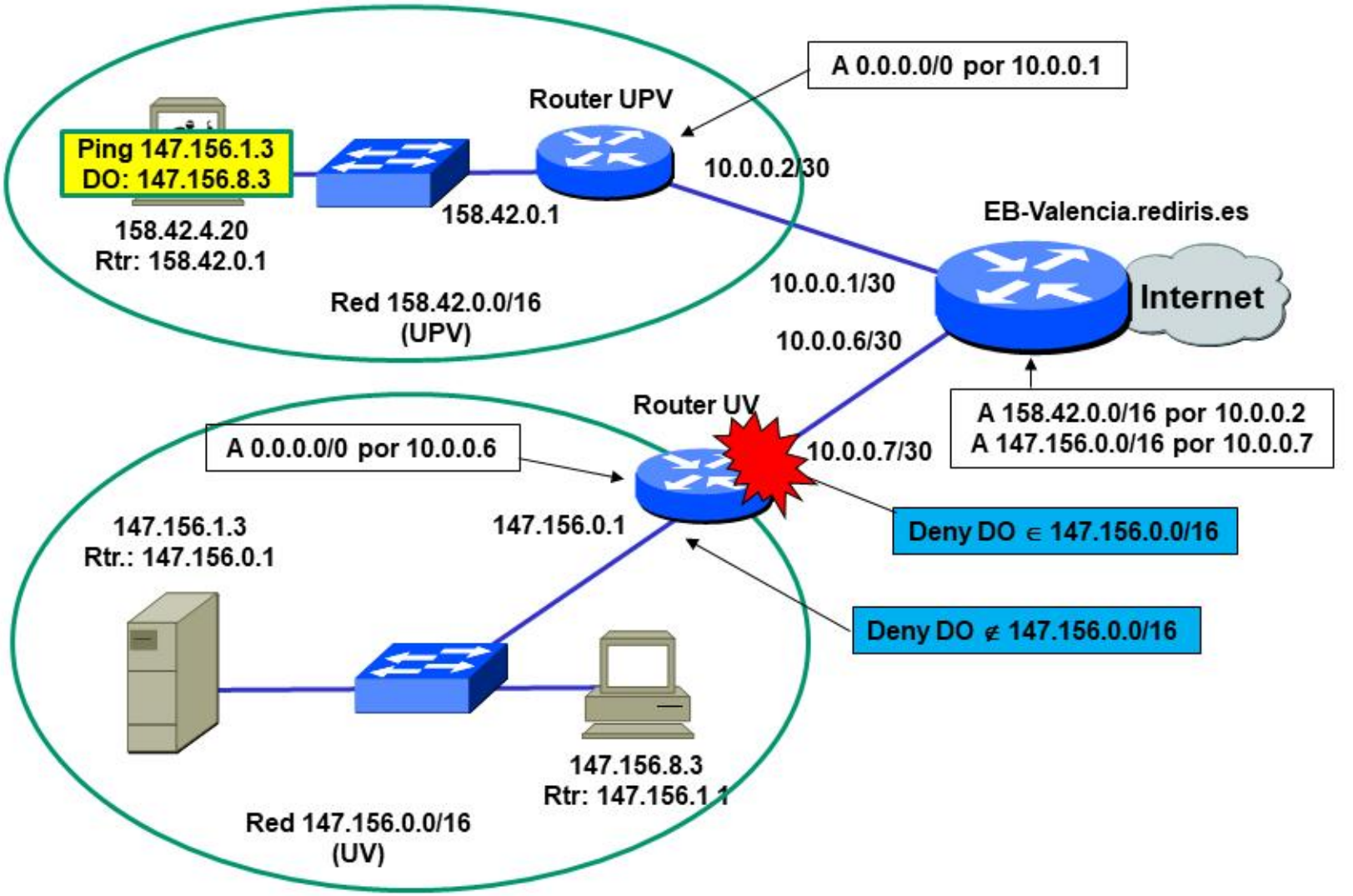
filtro anti-spoofing, RFC 2267

Consiste en no aceptar por una interfaz paquetes cuya IP de origen no corresponda con el rango esperado



El filtro anti-spoofing lo aplican habitualmente los ISPs a las conexiones de sus clientes.

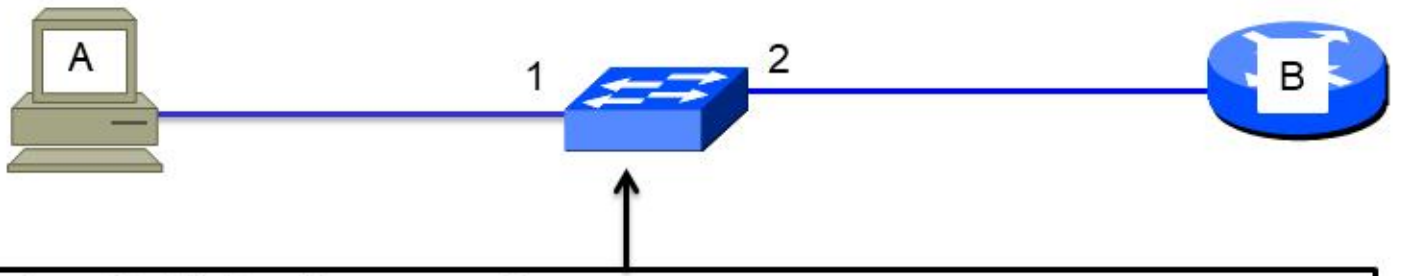
Efecto del filtro anti-spoofing



IP Spoofing en la misma LAN

- El filtro anti-spoofing no sirve cuando el impostor y el propietario de la IP están en la misma LAN, ya que en ese caso el router ve que el paquete viene de una interfaz legal
- La solución en ese caso es que el conmutador husmee la cabecera IP del paquete y vea si, según su binding table, esa IP corresponde a esa MAC (esto requiere tener activado el DHCP-snooping).
- Si la IP y la MAC no coinciden el paquete se descarta, y se puede llegar a desactivar el puerto
- Esta funcionalidad se conoce como **IP Source Guard**.

Configuración de switch ‘seguro’




```
sw(config)# ip dhcp snooping
sw(config)# ip arp inspection
sw(config)# interface 1
sw(config-if)# switchport port-security maximum 1
sw(config-if)# ip verify source port-security
sw(config)# interface 2
sw(config-if)# ip dhcp snooping trust
sw(config-if)# ip arp inspection trust
```

IP Source Guard

MAC Spoofing

- Se puede suplantar la identidad a nivel 2 (de la MAC) en la trama Ethernet.
- En ese caso, si el equipo suplantado se configura con BOOTP/DHCP, el IP spoofing va implícito. Y el ataque no puede evitarse con DHCP snooping.
- Atacante y suplantado han de estar en la misma LAN
- El MAC spoofing puede evitarse configurando estáticamente las tablas CAM en los conmutadores (MAC locking). De este modo quien usurpa la MAC tendría además que usurpar el puerto de conexión en el conmutador. El MAC locking es administrativamente muy laborioso y no suele hacerse.

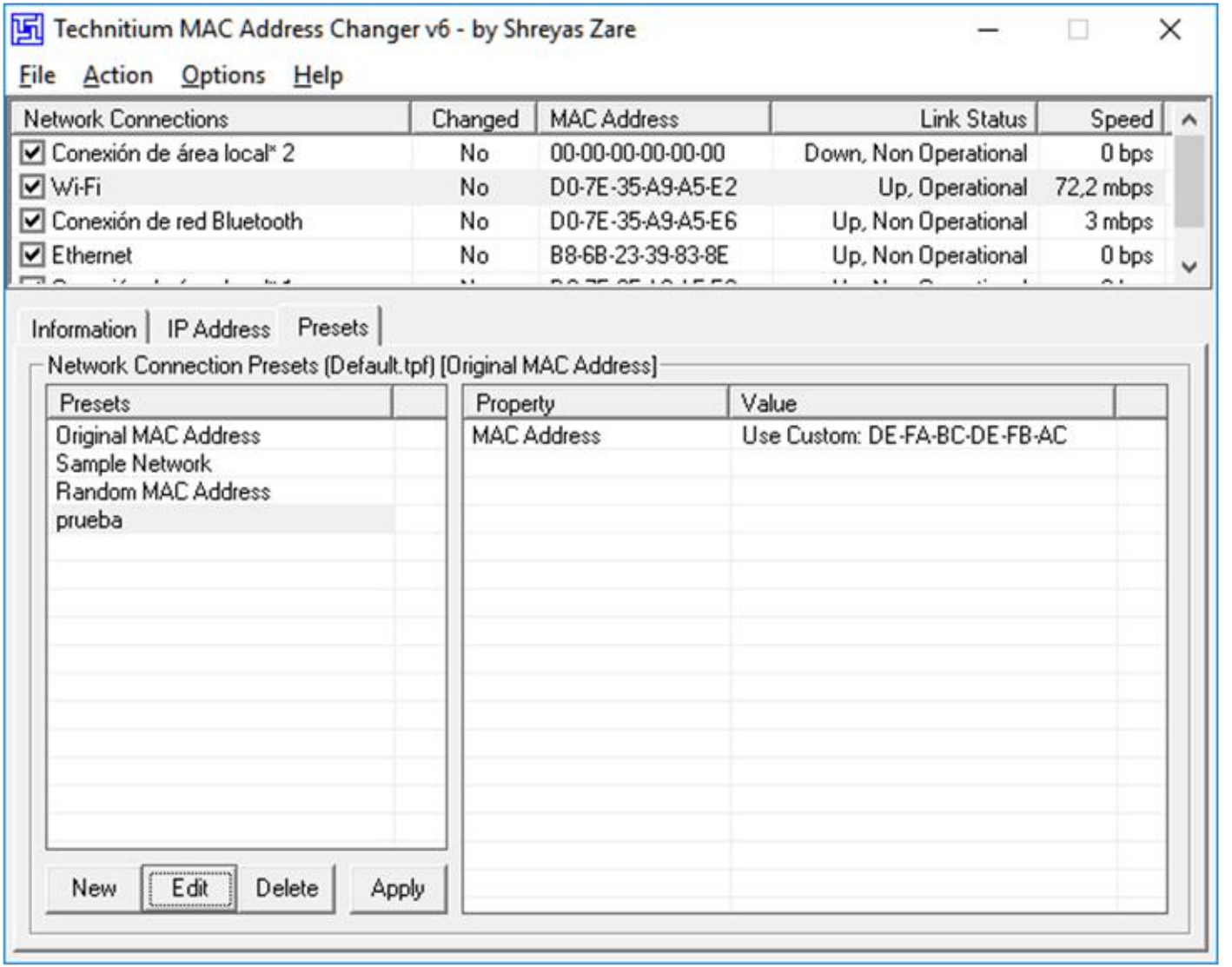
Como cambiar la MAC

- En todos los S. O. la MAC es fácil de cambiar
- En UNIX comandos de shell:

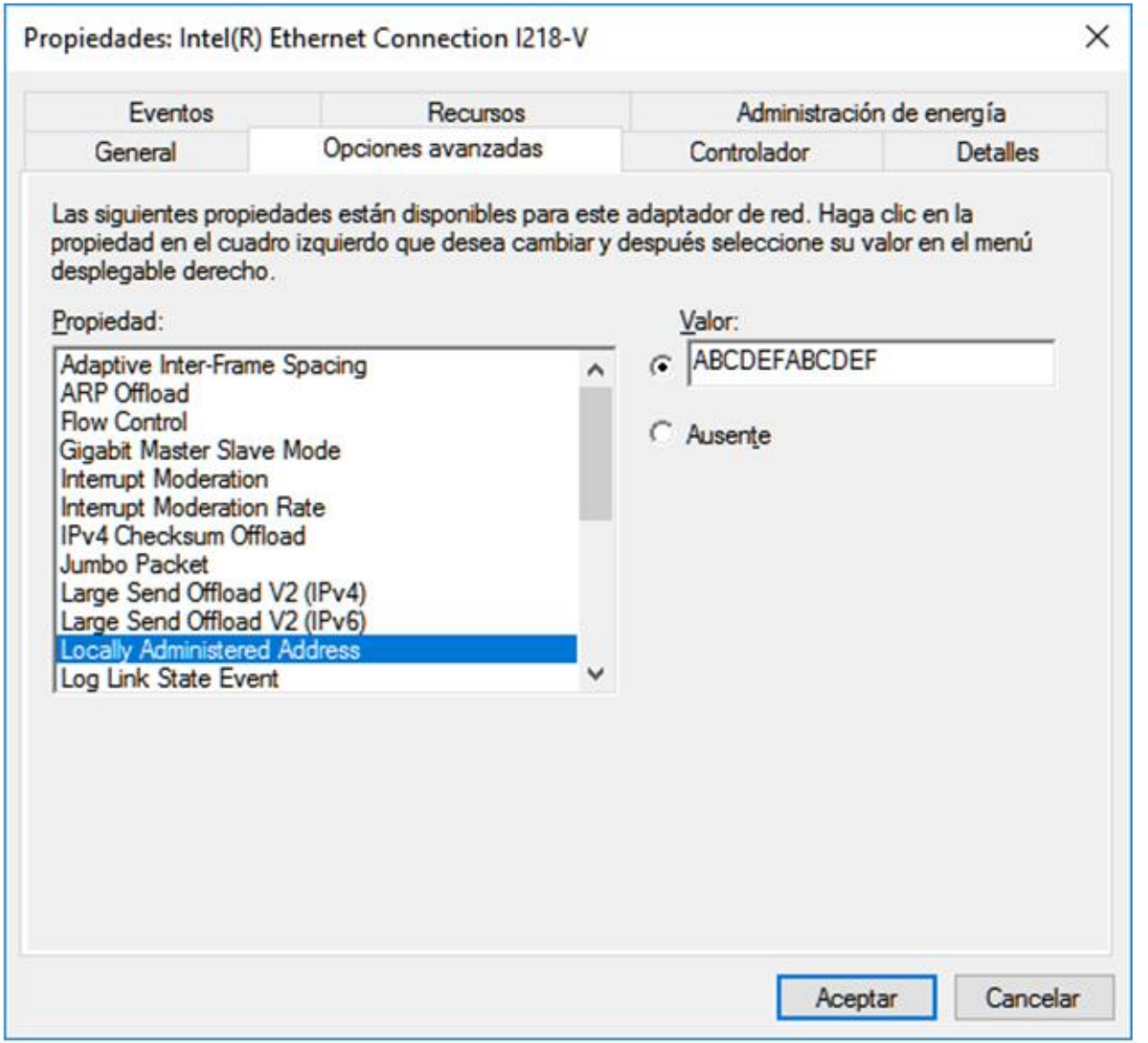
```
ifconfig eth0 down
ifconfig eth0 hw ether XX:XX:XX:XX:XX:XX
ifconfig eth0 up
```

- En Windows se puede usar un programa de cambio de la MAC, como 'Technitium MAC Address Changer'. Algunos drivers permiten hacer el cambio en'Propiedades del adaptador' 'Opciones avanzadas'

Windows: Cambio de MAC con Technitium



Windows: Cambio de MAC en propiedades del adaptador



Software para realizar ataques

- Hoy en día es muy fácil realizar ataques de todo tipo. Para ello no hace falta ser un experto en seguridad
- Hay herramientas (en Linux y en Windows) que permiten automatizar una gran variedad de ataques, suministrando al usuario directamente las combinaciones usuario/contraseña obtenidas

Cain & Abel: herramienta de recuperación de passwords (Windows)

Cain & Abel - User Manual

Copyright © 2001-2011 Massimiliano Montoro
All rights reserved

web site: http://www.oxid.it
email: mao@oxid.it

Cain & Abel is a password recovery tool for Microsoft Operating Systems. It allows easy recovery of several kind of passwords by sniffing the network, cracking encrypted passwords using Dictionary, Brute-Force and Cryptanalysis attacks, recording VoIP conversations, decoding scrambled passwords, recovering wireless network keys, revealing password boxes, uncovering cached passwords and analyzing routing protocols.

www.yersinia.net

Yersinia (Linux)

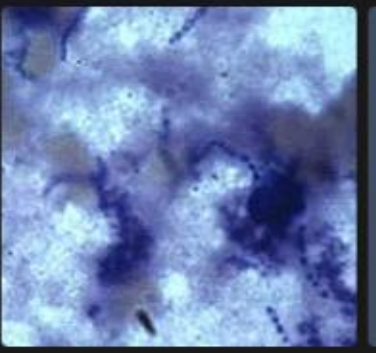
Yersinia

'ATRA MORS OMNES VITAM CAPIT'

NOTE: Current Yersinia version is 0.7.3 (Cisco VTP DoS exploit included!)

- Home
- Docs
- FAQ
- Download
- Attacks
- Screenshots
- About





Yersinia is a network tool designed to take advantage of some weakeness in different network protocols. It pretends to be a solid framework for analyzing and testing the deployed networks and systems.

Currently, there are some network protocols implemented, but others are coming (tell us which one is your preferred). Attacks for the following network protocols are implemented (but of course you are free for implementing new ones):

- Spanning Tree Protocol (STP)
- Cisco Discovery Protocol (CDP)
- Dynamic Trunking Protocol (DTP)
- Dynamic Host Configuration Protocol (DHCP)
- Hot Standby Router Protocol (HSRP)
- IEEE 802.1Q
- IEEE 802.1X
- Inter-Switch Link Protocol (ISL)
- VLAN Trunking Protocol (VTP)

Questions? Doubts? Recommendations? Flames? Please, visit the About section to know

Ataques de Yersinia
(más software en sectools.org)

Spanning Tree Protocol

1. Sending RAW Configuration BPDU
2. Sending RAW TCN BPDU
3. DoS sending RAW Configuration BPDU
4. DoS sending RAW TCN BPDU
5. Claiming Root Role
6. Claiming Other Role
7. Claiming Root Role dual home (MITM)

Cisco Discovery Protocol

1. Sending RAW CDP packet
2. DoS flooding CDP neighbors table
3. Setting up a virtual device

Dynamic Host Configuration Protocol

1. Sending RAW DHCP packet
2. DoS sending DISCOVER packet (exhausting ip pool)
3. Setting up rogue DHCP server
4. DoS sending RELEASE packet (releasing assigned ip)

Hot Standby Router Protocol

1. Sending RAW HSRP packet
2. Becoming active router
3. Becoming active router (MITM)

Dynamic Trunking Protocol

1. Sending RAW DTP packet
2. Enabling trunking

802.1Q

1. Sending RAW 802.1Q packet
2. Sending double encapsulated 802.1Q packet
3. Sending 802.1Q ARP Poisoning

802.1X

1. Sending RAW 802.1X packet
2. Mitm 802.1X with 2 interfaces

VLAN Trunking Protocol

1. Sending RAW VTP packet
2. Deleting ALL VLANs
3. Deleting selected VLAN
4. Adding one VLAN
5. Catalyst crash